Optical Store Management System - ZAP Security Assessment

ZAP 2.17.0. Isolated local assessment using synthetic data. Includes 13 manually verified findings explicitly prefixed [Manual verified], plus automatic passive scanner alerts. Manual findings were recorded against real ZAP History messages and were not automatically discovered. No unrestricted active scan or production testing was performed. /api/seed, external services and password-reset email delivery were excluded. The reset tests use a synthetic server-compatible token fixture. Severity reflects this application assessment; automatic informational alerts are not confirmed exploits.

Site: http://127.0.0.1:4010

Generated on Fri, 16 Oct 2026 15:39:47

ZAP Version: 2.17.0

ZAP by Checkmarx

Summary of Alerts

Risk Level	Number of Alerts
High	11
Medium	5
Low	4
Informational	1
False Positives:	0

Alerts

Name	Risk Level	Number of Instances
PII Disclosure	High	2
[Manual verified] Client-controlled order price and total	High	1
[Manual verified] Cross-user order disclosure (IDOR)	High	1
[Manual verified] Cross-user payment status modification (IDOR)	High	1
[Manual verified] Full card number and CVV persisted and returned by API	High	1
[Manual verified] Order marked paid without payment-provider verification	High	1
[Manual verified] Ordinary user can mark another user's order delivered	High	1
[Manual verified] Password reset token can be reused after successful reset	High	1
[Manual verified] Password-reset JWT accepted as an API access token	High	1

[Manual verified] Patient prescription disclosure to an unrelated user	High	1
[Manual verified] Patient prescription modification by an unrelated user	High	1
Content Security Policy (CSP) Header Not Set	Medium	Systemic
Missing Anti-clickjacking Header	Medium	Systemic
Sub Resource Integrity Attribute Missing	Medium	Systemic
[Manual verified] Cross-user support ticket response injection	Medium	1
[Manual verified] Single-character password accepted by registration API	Medium	1
Application Error Disclosure	Low	1
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	Systemic
X-Content-Type-Options Header Missing	Low	Systemic
[Manual verified] Internal database implementation details exposed in error response	Low	1
Modern Web Application	Informational	Systemic

Alert Detail

High	PII Disclosure
Description	The response contains Personally Identifiable Information, such as CC number, SSN and similar sensitive data.
URL	http://127.0.0.1:4010/api/card-details
Node Name	http://127.0.0.1:4010/api/card-details
Method	GET
Attack	
Evidence	4111111111111111
Other Info	Credit Card Type detected: Visa Bank Identification Number: 411111 Brand: VISA Category: CLASSIC Issuer: CONOTOXIA SP. Z O.O
URL	http://127.0.0.1:4010/api/card-details
Node Name	http://127.0.0.1:4010/api/card-details ()({cardHolderName,cardNumber,expiryDate,cvv, cardType})
Method	POST
Attack	
Evidence	4111111111111111
Other Info	Credit Card Type detected: Visa Bank Identification Number: 411111 Brand: VISA

	Category: CLASSIC Issuer: CONOTOXIA SP. Z O.O
Instances	2
Solution	Check the response for the potential presence of personally identifiable information (PII), ensure nothing sensitive is leaked by the application.
Reference	
CWE Id	359
WASC Id	13
Plugin Id	10062

High	**[Manual verified] Client-controlled order price and total**
Description	VIVA-05: A product priced at 100 in the fixture catalog was ordered with price and total 0.01. Verified against synthetic fixtures in an isolated local database. Detection: manual HTTP test through ZAP proxy, not an automatic scanner finding.
URL	http://127.0.0.1:4010/api/orders
Node Name	http://127.0.0.1:4010/api/orders ()({orderItems:[{_id,product,slug,name,quantity,image, price}],shippingAddress:{fullName,address,city,postalCode,country},paymentMethod, itemsPrice,shippingPrice,taxPrice,totalPrice})
Method	POST
Attack	
Evidence	A product priced at 100 in the fixture catalog was ordered with price and total 0.01.
Other Info	Source: ICare/backend/routes/orderRoutes.js:26 History marker: viva-0011 VIVA-05
Instances	1
Solution	Load catalog prices server-side and recalculate all totals, taxes and shipping.
Reference	https://cwe.mitre.org/data/definitions/602.html
CWE Id	602
WASC Id	
Plugin Id	

High	**[Manual verified] Cross-user order disclosure (IDOR)**
Description	VIVA-01: Alice received Bob's synthetic order and shipping address; anonymous control returned 401. Verified against synthetic fixtures in an isolated local database. Detection: manual HTTP test through ZAP proxy, not an automatic scanner finding.
URL	http://127.0.0.1:4010/api/orders/6ad1f5d544cd2ebcf79b4619
Node Name	http://127.0.0.1:4010/api/orders/6ad1f5d544cd2ebcf79b4619
Method	GET
Attack	
Evidence	Alice received Bob's synthetic order and shipping address; anonymous control returned 401.
Other	Source: ICare/backend/routes/orderRoutes.js:107 History marker: viva-0005

Info	VIVA-01
Instances	1
Solution	Require ownership or an administrator role before returning an order.
Reference	https://cwe.mitre.org/data/definitions/639.html
CWE Id	639
WASC Id	
Plugin Id	

High	[Manual verified] Cross-user payment status modification (IDOR)
Description	VIVA-04: Alice marked Bob's separate order paid. This tests ownership independently of the missing provider verification. Verified against synthetic fixtures in an isolated local database. Detection: manual HTTP test through ZAP proxy, not an automatic scanner finding.
URL	http://127.0.0.1:4010/api/orders/6ad1f5d544cd2ebcf79b4619/pay
Node Name	http://127.0.0.1:4010/api/orders/6ad1f5d544cd2ebcf79b4619/pay ()({})
Method	PUT
Attack	
Evidence	Alice marked Bob's separate order paid. This tests ownership independently of the missing provider verification.
Other Info	Source: ICare/backend/routes/orderRoutes.js:142 History marker: viva-0010 VIVA-04
Instances	1
Solution	Bind payment changes to the authorized order owner or trusted payment webhook.
Reference	https://cwe.mitre.org/data/definitions/639.html
CWE Id	639
WASC Id	
Plugin Id	

High	[Manual verified] Full card number and CVV persisted and returned by API
Description	VIVA-09: A subsequent GET returned the full synthetic test PAN and CVV. Source review also shows ordinary string persistence without field encryption. Verified against synthetic fixtures in an isolated local database. Detection: manual HTTP test through ZAP proxy, not an automatic scanner finding.
URL	http://127.0.0.1:4010/api/card-details
Node Name	http://127.0.0.1:4010/api/card-details
Method	GET
Attack	
Evidence	A subsequent GET returned the full synthetic test PAN and CVV. Source review also shows ordinary string persistence without field encryption.
Other	Source: ICare/backend/models/cardModel.js:7; ICare/backend/routes/cardRoutes.js:35 History marker: viva-0018

Info	VIVA-09
Instances	1
Solution	Use payment-provider tokenization, remove stored CVVs, and return only masked card metadata.
Reference	https://cwe.mitre.org/data/definitions/312.html
CWE Id	312
WASC Id	
Plugin Id	

High	**[Manual verified] Order marked paid without payment-provider verification**
Description	VIVA-03: An empty JSON request marked an unpaid PayPal order paid; no payment proof was supplied. External integrations were disabled. Verified against synthetic fixtures in an isolated local database. Detection: manual HTTP test through ZAP proxy, not an automatic scanner finding.
URL	http://127.0.0.1:4010/api/orders/6ad1f5d5d26058fe7c284c49/pay
Node Name	http://127.0.0.1:4010/api/orders/6ad1f5d5d26058fe7c284c49/pay ()({})
Method	PUT
Attack	
Evidence	An empty JSON request marked an unpaid PayPal order paid; no payment proof was supplied. External integrations were disabled.
Other Info	Source: ICare/backend/routes/orderRoutes.js:137 History marker: viva-0009 VIVA-03
Instances	1
Solution	Verify provider capture server-side, amount, currency and ownership before recording payment.
Reference	https://cwe.mitre.org/data/definitions/841.html
CWE Id	841
WASC Id	
Plugin Id	

High	**[Manual verified] Ordinary user can mark another user's order delivered**
Description	VIVA-02: A non-admin changed Bob's isDelivered from false to true. Verified against synthetic fixtures in an isolated local database. Detection: manual HTTP test through ZAP proxy, not an automatic scanner finding.
URL	http://127.0.0.1:4010/api/orders/6ad1f5d544cd2ebcf79b4619/deliver
Node Name	http://127.0.0.1:4010/api/orders/6ad1f5d544cd2ebcf79b4619/deliver ()({})
Method	PUT
Attack	
Evidence	A non-admin changed Bob's isDelivered from false to true.
Other	Source: ICare/backend/routes/orderRoutes.js:121 History marker: viva-0006

Info	VIVA-02
Instances	1
Solution	Enforce isAdmin on delivery changes and audit state transitions.
Reference	https://cwe.mitre.org/data/definitions/862.html
CWE Id	862
WASC Id	
Plugin Id	

High	**[Manual verified] Password reset token can be reused after successful reset**
Description	VIVA-10: The same server-compatible fixture reset token changed the password twice; login confirmed the second password. Token seeded directly to avoid sending reset email. Verified against synthetic fixtures in an isolated local database. Detection: manual HTTP test through ZAP proxy, not an automatic scanner finding.
URL	http://127.0.0.1:4010/api/users/reset-password
Node Name	http://127.0.0.1:4010/api/users/reset-password ()({token,password})
Method	POST
Attack	
Evidence	The same server-compatible fixture reset token changed the password twice; login confirmed the second password. Token seeded directly to avoid sending reset email.
Other Info	Source: ICare/backend/routes/userRoutes.js:107 History marker: viva-0020 VIVA-10
Instances	1
Solution	Consume the reset token atomically after success, store its hash, and revoke affected sessions.
Reference	https://cwe.mitre.org/data/definitions/640.html
CWE Id	640
WASC Id	
Plugin Id	

High	**[Manual verified] Password-reset JWT accepted as an API access token**
Description	VIVA-11: A JWT containing only the reset-flow user ID was accepted as a Bearer token and returned the fixture card. Fixture token uses the app's reset signing logic. Verified against synthetic fixtures in an isolated local database. Detection: manual HTTP test through ZAP proxy, not an automatic scanner finding.
URL	http://127.0.0.1:4010/api/card-details
Node Name	http://127.0.0.1:4010/api/card-details
Method	GET
Attack	
Evidence	A JWT containing only the reset-flow user ID was accepted as a Bearer token and returned the fixture card. Fixture token uses the app's reset signing logic.
	Source: ICare/backend/utils.js:27; ICare/backend/routes/userRoutes.js:73

Other Info	History marker: viva-0022 VIVA-11
Instances	1
Solution	Validate token purpose/type, audience and issuer; separate reset and access token validation.
Reference	https://cwe.mitre.org/data/definitions/287.html
CWE Id	287
WASC Id	
Plugin Id	

High	[Manual verified] Patient prescription disclosure to an unrelated user
Description	VIVA-06: Alice read the synthetic Bob Demo prescription using a normal customer token. Verified against synthetic fixtures in an isolated local database. Detection: manual HTTP test through ZAP proxy, not an automatic scanner finding.
URL	http://127.0.0.1:4010/api/prescriptions/6ad1f5d544cd2ebcf79b4620
Node Name	http://127.0.0.1:4010/api/prescriptions/6ad1f5d544cd2ebcf79b4620
Method	GET
Attack	
Evidence	Alice read the synthetic Bob Demo prescription using a normal customer token.
Other Info	Source: ICare/backend/routes/prescriptionRoutes.js:41 History marker: viva-0012 VIVA-06
Instances	1
Solution	Associate prescriptions with a patient and authorize the patient or assigned clinician.
Reference	https://cwe.mitre.org/data/definitions/862.html
CWE Id	862
WASC Id	
Plugin Id	

High	[Manual verified] Patient prescription modification by an unrelated user
Description	VIVA-07: Alice changed another patient's synthetic prescription without a clinician/admin role. Verified against synthetic fixtures in an isolated local database. Detection: manual HTTP test through ZAP proxy, not an automatic scanner finding.
URL	http://127.0.0.1:4010/api/prescriptions/6ad1f5d544cd2ebcf79b4620
Node Name	http://127.0.0.1:4010/api/prescriptions/6ad1f5d544cd2ebcf79b4620 ()({prescriptionDetails})
Method	PUT
Attack	
Evidence	Alice changed another patient's synthetic prescription without a clinician/admin role.
Other Info	Source: ICare/backend/routes/prescriptionRoutes.js:55 History marker: viva-0013

	VIVA-07
Instances	1
Solution	Restrict medical record changes to authorized clinicians and enforce object-level permissions.
Reference	https://cwe.mitre.org/data/definitions/862.html
CWE Id	862
WASC Id	
Plugin Id	

Medium	**Content Security Policy (CSP) Header Not Set**
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://127.0.0.1:4010/
Node Name	http://127.0.0.1:4010/
Method	GET
Attack	
Evidence	
Other Info	
URL	http://127.0.0.1:4010/signin
Node Name	http://127.0.0.1:4010/signin
Method	GET
Attack	
Evidence	
Other Info	
URL	http://127.0.0.1:4010/signup
Node Name	http://127.0.0.1:4010/signup
Method	GET
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp

	https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Missing Anti-clickjacking Header
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	http://127.0.0.1:4010/
Node Name	http://127.0.0.1:4010/
Method	GET
Attack	
Evidence	
Other Info	
URL	http://127.0.0.1:4010/signin
Node Name	http://127.0.0.1:4010/signin
Method	GET
Attack	
Evidence	
Other Info	
URL	http://127.0.0.1:4010/signup
Node Name	http://127.0.0.1:4010/signup
Method	GET
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Medium	Sub Resource Integrity Attribute Missing

Description	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.
URL	http://127.0.0.1:4010/
Node Name	http://127.0.0.1:4010/
Method	GET
Attack	
Evidence	<link rel="stylesheet" href="https://cdn.jsdelivr.net/npm/@fortawesome/fontawesome-free@5.15.4/css/all.min.css"/>
Other Info	
URL	http://127.0.0.1:4010/signin
Node Name	http://127.0.0.1:4010/signin
Method	GET
Attack	
Evidence	<link rel="stylesheet" href="https://cdn.jsdelivr.net/npm/@fortawesome/fontawesome-free@5.15.4/css/all.min.css"/>
Other Info	
URL	http://127.0.0.1:4010/signup
Node Name	http://127.0.0.1:4010/signup
Method	GET
Attack	
Evidence	<link rel="stylesheet" href="https://cdn.jsdelivr.net/npm/@fortawesome/fontawesome-free@5.15.4/css/all.min.css"/>
Other Info	
Instances	Systemic
Solution	Provide a valid integrity attribute to the tag.
Reference	https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity
CWE Id	345
WASC Id	15
Plugin Id	90003

Medium	**[Manual verified] Cross-user support ticket response injection**
Description	VIVA-08: Alice could not read Bob's ticket (404), but could append a response (201), confirmed using Bob's token. Verified against synthetic fixtures in an isolated local database. Detection: manual HTTP test through ZAP proxy, not an automatic scanner finding.
URL	http://127.0.0.1:4010/api/tickets/6ad1f5d544cd2ebcf79b461c/responses
Node Name	http://127.0.0.1:4010/api/tickets/6ad1f5d544cd2ebcf79b461c/responses ()({message})
Method	POST
Attack	

Evidence	Alice could not read Bob's ticket (404), but could append a response (201), confirmed using Bob's token.
Other Info	Source: ICare/backend/routes/ticketRoutes.js:122 History marker: viva-0015 VIVA-08
Instances	1
Solution	Apply the same owner/admin check to ticket response creation as ticket reads.
Reference	https://cwe.mitre.org/data/definitions/639.html
CWE Id	639
WASC Id	
Plugin Id	

Medium	**[Manual verified] Single-character password accepted by registration API**
Description	VIVA-12: Registration succeeded and issued a token for the one-character password a; the request bypassed browser-only validation. Verified against synthetic fixtures in an isolated local database. Detection: manual HTTP test through ZAP proxy, not an automatic scanner finding.
URL	http://127.0.0.1:4010/api/users/signup
Node Name	http://127.0.0.1:4010/api/users/signup ()({name,email,password,nic,address,phone})
Method	POST
Attack	
Evidence	Registration succeeded and issued a token for the one-character password a; the request bypassed browser-only validation.
Other Info	Source: ICare/backend/routes/userRoutes.js:197 History marker: viva-0023 VIVA-12
Instances	1
Solution	Apply a server-side password length policy and breached-password checks.
Reference	https://cwe.mitre.org/data/definitions/521.html
CWE Id	521
WASC Id	
Plugin Id	

Low	**Application Error Disclosure**
Description	This page contains an error/warning message that may disclose sensitive information like the location of the file that produced the unhandled exception. This information can be used to launch further attacks against the web application. The alert could be a false positive if the error message is found inside a documentation page.
URL	http://127.0.0.1:4010/api/orders/not-a-valid-object-id
Node Name	http://127.0.0.1:4010/api/orders/not-a-valid-object-id
Method	GET
Attack	
Evidence	HTTP/1.1 500 Internal Server Error

Other Info	
Instances	1
Solution	Review the source code of this page. Implement custom error pages. Consider implementing a mechanism to provide a unique error reference/identifier to the client (browser) while logging the details on the server side and not exposing them to the user.
Reference	
CWE Id	550
WASC Id	13
Plugin Id	90022

Low	**Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)**
Description	The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to.
URL	http://127.0.0.1:4010/
Node Name	http://127.0.0.1:4010/
Method	GET
Attack	
Evidence	X-Powered-By: Express
Other Info	
URL	http://127.0.0.1:4010/signin
Node Name	http://127.0.0.1:4010/signin
Method	GET
Attack	
Evidence	X-Powered-By: Express
Other Info	
URL	http://127.0.0.1:4010/signup
Node Name	http://127.0.0.1:4010/signup
Method	GET
Attack	
Evidence	X-Powered-By: Express
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.
Reference	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13

Plugin Id	10037

Low	**X-Content-Type-Options Header Missing**
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://127.0.0.1:4010/
Node Name	http://127.0.0.1:4010/
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://127.0.0.1:4010/signin
Node Name	http://127.0.0.1:4010/signin
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://127.0.0.1:4010/signup
Node Name	http://127.0.0.1:4010/signup
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	Systemic
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693

WASC Id	15
Plugin Id	10021

Low	[Manual verified] Internal database implementation details exposed in error response
Description	VIVA-13: Malformed order ID returned HTTP 500 with a database ObjectId cast error rather than a generic validation error. Verified against synthetic fixtures in an isolated local database. Detection: manual HTTP test through ZAP proxy, not an automatic scanner finding.
URL	http://127.0.0.1:4010/api/orders/not-a-valid-object-id
Node Name	http://127.0.0.1:4010/api/orders/not-a-valid-object-id
Method	GET
Attack	
Evidence	Malformed order ID returned HTTP 500 with a database ObjectId cast error rather than a generic validation error.
Other Info	Source: ICare/backend/server.js:65; ICare/backend/routes/orderRoutes.js:112 History marker: viva-0024 VIVA-13
Instances	1
Solution	Validate identifiers, return 400 for invalid input, and keep internal errors in private logs.
Reference	https://cwe.mitre.org/data/definitions/209.html
CWE Id	209
WASC Id	
Plugin Id	

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.
URL	http://127.0.0.1:4010/
Node Name	http://127.0.0.1:4010/
Method	GET
Attack	
Evidence	<script defer="defer" src="/static/js/main.914fda09.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://127.0.0.1:4010/signin
Node Name	http://127.0.0.1:4010/signin
Method	GET
Attack	
Evidence	<script defer="defer" src="/static/js/main.914fda09.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://127.0.0.1:4010/signup

Node Name	http://127.0.0.1:4010/signup
Method	GET
Attack	
Evidence	<script defer="defer" src="/static/js/main.914fda09.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	Systemic
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109